

FUNDD

Financial Services

Information Technology Security Policy

Covering: Acceptable Use | Data & Privacy | Access Control | Remote Work & BYOD | Breach Response

Version: 1.0

Effective Date: April 2026

Classification: Confidential – Internal Use Only

Owner: Chief Information Security Officer (CISO)

Review Cycle: Annual (or following any material breach)

CONFIDENTIAL

Table of Contents

1. Introduction and Purpose

Fundd operates within a heavily regulated financial services environment and is subject to applicable Australian privacy, cybersecurity, and financial services laws including but not limited to the Privacy Act 1988, the Australian Privacy Principles (APPs), and obligations under the Corporations Act 2001 and ASIC regulatory guidance.

This IT Security Policy establishes the rules, standards, and responsibilities governing the use of Fundd's information technology resources. It applies to all employees, contractors, consultants, and third-party service providers who access Fundd's systems, data, or networks.

The objectives of this policy are to:

- Protect the confidentiality, integrity, and availability of Fundd's information assets and client data.
- Ensure compliance with legal, regulatory, and contractual obligations.
- Define acceptable and unacceptable use of IT resources.
- Establish a clear, tiered framework for responding to security incidents and data breaches.
- Promote a culture of security awareness across the organisation.

Non-compliance with this policy may result in disciplinary action up to and including termination of employment or contract, and may attract civil or criminal liability.

2. Scope

This policy applies to:

- All Fundd employees (full-time, part-time, and casual).
- Contractors, consultants, and temporary staff.
- Third-party vendors and service providers with access to Fundd systems or data.
- All company-owned, leased, or personally-owned devices used to access Fundd systems (including BYOD).
- All physical and cloud-based IT systems, networks, and data repositories managed by or on behalf of Fundd.

By accessing any Fundd IT resource, all individuals are deemed to have read, understood, and agreed to comply with this policy.

3. Acceptable Use Policy

3.1 General Principles

Fundd's IT resources — including computers, mobile devices, networks, software, email systems, and internet access — are provided for legitimate business purposes. Personal use is permitted on a limited and incidental basis provided it does not:

- Interfere with business operations or productivity.
- Violate any provision of this policy or applicable law.
- Consume excessive bandwidth, storage, or system resources.
- Expose Fundd to legal, regulatory, or reputational risk.

3.2 Permitted Uses

The following uses are permitted:

- Accessing company systems and data necessary to perform assigned job functions.
- Communicating with clients, partners, and colleagues via authorised channels.
- Using company-approved software and cloud services.
- Incidental personal use that does not conflict with this policy.

3.3 Prohibited Uses

The following activities are strictly prohibited on Fundd IT resources:

- Accessing, transmitting, or storing offensive, defamatory, discriminatory, or pornographic material.
- Downloading, installing, or running unauthorised software, scripts, or executables.
- Using Fundd resources for cryptocurrency mining, gambling, or personal commercial activities.
- Attempting to bypass, circumvent, or disable security controls, firewalls, or monitoring tools.
- Sharing credentials or permitting others to use your accounts.
- Transmitting client or confidential data via unapproved channels (e.g., personal email, USB drives).
- Using company systems to access or distribute pirated software or illegal content.
- Using social media to disclose confidential or client information.
- Connecting to Fundd systems via unsecured or public Wi-Fi without an approved VPN.

3.4 Monitoring

Fundd reserves the right to monitor, log, and audit the use of its IT systems at any time and without prior notice, to the extent permitted by applicable law. Users should have no expectation of privacy when using Fundd-owned or Fundd-administered resources. Monitoring may include email, web browsing activity, file transfers, and application usage.

4. Data and Privacy Policy

4.1 Data Classification

All data held or processed by Fundd must be classified according to the following framework:

Classification	Examples	Handling Requirements
Public	Marketing materials, public announcements	May be shared freely. No restrictions.
Internal	Internal procedures, org charts	For internal use only. Not for external distribution.
Confidential	Financial reports, contracts, staff records	Restricted to authorised personnel. Must be encrypted in transit.
Highly Confidential	Client PII, account data, regulatory filings	Strict access controls. Encrypted at rest and in transit. Audit log required.

4.2 Collection and Use Limitation

Data must only be collected for a lawful, specified purpose and must not be used in a manner incompatible with that purpose. Data minimisation principles apply — only data necessary to fulfill the stated purpose should be collected.

4.3 Storage and Retention

- All client and personal data must be stored in approved, secure systems located in Australia or jurisdictions approved by the CISO.
- Data must be retained only for as long as required by law, regulation, or legitimate business need.
- Upon expiry of the retention period, data must be securely deleted or anonymised in accordance with Fundd's Data Retention Schedule.

4.4 Data in Transit and at Rest

- All Highly Confidential and Confidential data must be encrypted using industry-standard encryption (minimum AES-256 at rest, TLS 1.2+ in transit).
- Emails containing sensitive data must use approved secure messaging channels or encrypted attachments.
- Portable storage devices (USB drives, external HDDs) are prohibited unless explicitly approved and encrypted.

4.5 Third-Party Data Sharing

Data must not be shared with third parties without a signed Data Processing Agreement (DPA) or equivalent contractual protection confirming appropriate security controls and compliance with the Privacy Act 1988. The CISO must approve any new third-party data sharing arrangement.

4.6 Privacy Breach Notification

Fundd is subject to the Notifiable Data Breaches (NDB) scheme under the Privacy Act 1988. Any actual or suspected data breach involving personal information must be reported to the IT Security team immediately. Where a breach is likely to result in serious harm to affected individuals, the Office of the Australian Information Commissioner (OAIC) and affected individuals must be notified within 30 days of becoming aware of the breach.

5. Access Control Policy

5.1 Principle of Least Privilege

Access to Fundd systems and data must be granted on the basis of least privilege — users should have access only to the resources necessary to perform their specific role. Access rights must be reviewed at least annually and revoked immediately upon role change or departure.

5.2 User Account Management

- All access to Fundd systems requires a unique, individually assigned account. Shared accounts are prohibited.
- Account provisioning must be approved by the user's line manager and actioned by IT within 2 business days.
- Accounts for departing employees or contractors must be disabled on or before their last day of access.
- Dormant accounts (inactive for 60+ days) must be automatically disabled.

5.3 Password Standards

All passwords and passphrases must meet the following minimum requirements:

- Minimum 14 characters in length.
- Must include at least one uppercase letter, one lowercase letter, one number, and one special character.
- Must not contain the user's name, username, or commonly used words.
- Must not be reused from the previous 12 passwords.
- Must be changed immediately if suspected to be compromised.

Password managers approved by IT (e.g., 1Password, Bitwarden Enterprise) must be used for all work accounts. Writing passwords on paper or storing them in plain text is prohibited.

5.4 Multi-Factor Authentication (MFA)

MFA is mandatory for:

- All remote access to Fundd systems.
- All cloud-based services and SaaS platforms.
- All privileged and administrative accounts.
- All access to financial systems and client data repositories.

TOTP-based authenticator applications (e.g., Google Authenticator, Microsoft Authenticator) or hardware tokens are the preferred MFA methods. SMS-based MFA is discouraged and must not be used for highly privileged accounts.

5.5 Privileged Access

- Administrator and privileged accounts must be used only when required and must be separate from standard user accounts.
- All privileged access activities must be logged and subject to regular audit.
- Remote privileged access requires a Privileged Access Workstation (PAW) or equivalent hardened device.

5.6 Physical Access

Physical access to server rooms, data centres, and areas containing sensitive equipment is restricted to authorised personnel. Access must be logged. Visitors must be escorted at all times. Tailgating is prohibited.

6. Remote Work and BYOD Policy

6.1 Remote Work Standards

Fundd supports flexible working arrangements. All employees working remotely must adhere to the same security standards as if working from a Fundd office. The following requirements apply:

- A VPN connection to the Fundd network is mandatory when accessing internal systems from outside the office.
- Remote work sessions must be conducted in a private, secure environment where screens cannot be observed by unauthorised individuals.
- Video conferencing tools must be approved by IT. Default-open or unauthenticated meeting links must not be used for confidential discussions.
- Data must not be printed or stored locally unless authorised by the CISO for a specific business purpose.

6.2 Network Security

- Employees must not connect to Fundd systems via unsecured public Wi-Fi without an active, approved VPN connection.
- Home routers must use WPA2 or WPA3 encryption. ISP-default router passwords must be changed.
- Guest Wi-Fi networks at home must be kept separate from the network used for Fundd work.

6.3 BYOD (Bring Your Own Device)

Use of personal devices to access Fundd systems is permitted subject to the following conditions:

- The device must be registered with IT and enrolled in Fundd's Mobile Device Management (MDM) solution.
- The device must run a supported, up-to-date operating system with current security patches applied.
- Device-level encryption must be enabled.
- A strong screen lock (PIN of 6+ digits or biometric) must be active with auto-lock set to 5 minutes or less.
- Fundd reserves the right to remotely wipe corporate data from a BYOD device if it is lost, stolen, compromised, or upon termination of employment. Employees must consent to this condition prior to registering a personal device.

6.4 Device Loss or Theft

Any lost or stolen device used to access Fundd systems must be reported to IT Security immediately (within 2 hours of discovery). IT will initiate a remote lock or wipe as appropriate and document the incident in the security incident register.

6.5 Endpoint Protection

- All devices accessing Fundd systems must have approved endpoint protection (antivirus/EDR) software installed and active.
- Operating systems and applications must be updated within 14 days of a critical patch release, or immediately in the event of an actively exploited vulnerability.
- Jailbroken or rooted devices are prohibited from accessing Fundd systems.

7. Security Breach Severity Framework

All security incidents must be classified according to the four-tier severity framework below. The severity level determines the escalation path, response timeline, and notification obligations. Initial classification is made by the first responder and may be escalated as additional information comes to hand.

Level	Name	Description
SEV-1	Critical	Confirmed breach of Highly Confidential data; active ransomware or malware with ongoing impact; regulatory-reportable breach; systems-wide outage affecting critical financial operations.
SEV-2	High	Potential breach of Confidential data; significant unauthorised access to internal systems; targeted phishing attack with credentials compromised; single critical system unavailable.
SEV-3	Medium	Suspected but unconfirmed breach; policy violation with potential data exposure; malware detected but contained; loss of a registered but locked BYOD device.
SEV-4	Low	Minor policy violations; isolated phishing email with no compromise; software vulnerability with no active exploitation; loss of non-sensitive data.

7.1 Escalation Matrix

Level	Response Time	Notify	Escalate To	Regulatory Notice
SEV-1 Critical	Immediate (< 1 hour)	CISO, CEO, Legal	Incident Response Team (IRT)	OAIC within 30 days if NDB
SEV-2 High	< 4 hours	CISO, IT Manager	CISO, IT Security Team	Assess for NDB obligation
SEV-3 Medium	< 24 hours	IT Manager	IT Security Team	Typically not required
SEV-4 Low	< 72 hours	IT Helpdesk	IT Helpdesk	Not required

Note: All incidents regardless of severity must be logged in the Security Incident Register within 24 hours of detection. The full Incident Response Runbook details step-by-step response procedures for each severity level.

8. Compliance and Enforcement

8.1 Policy Compliance

Compliance with this policy is mandatory. Fundd's IT Security team is responsible for monitoring and auditing compliance on an ongoing basis. Annual audits will be conducted to assess adherence, and findings will be reported to the CISO and executive leadership.

8.2 Consequences of Non-Compliance

Breaches of this policy will be handled in accordance with Fundd's HR policies and may result in:

- Formal warning or counselling.
- Suspension of IT access rights.
- Disciplinary action up to and including termination of employment.
- Civil or criminal liability where a breach results in loss or harm to clients or the company.

8.3 Policy Exceptions

Any exceptions to this policy must be submitted in writing to the CISO for review and approval. Exceptions must include a documented business justification and a risk assessment. Approved exceptions must be reviewed at least annually.

8.4 Reporting Security Concerns

Employees are encouraged to report suspected policy violations, security incidents, or vulnerabilities without fear of retaliation. Reports can be made to:

- IT Security team: security@fundd.com.au
- CISO directly (for sensitive matters).
- Fundd's whistleblower hotline (for concerns involving senior staff).

9. Policy Review and Governance

This policy will be reviewed at least annually by the CISO and updated to reflect changes in legislation, technology, threat landscape, and business operations. Ad hoc reviews will be triggered by:

- A material security incident or breach.
- Significant changes to Fundd's IT infrastructure or business model.
- Updates to relevant legislation or regulatory guidance.

All policy updates must be approved by the CISO and notified to all staff within 5 business days of adoption.

Version	Date	Author	Summary of Changes
1.0	April 2026	CISO	Initial policy release.

10. Acknowledgement

By accessing Fundd's IT systems, all users acknowledge that they have read, understood, and agree to comply with this IT Security Policy. New employees and contractors must sign the acknowledgement form below as part of their onboarding process.

Full Name (Print)

Date

Signature

Position

Manager / Supervisor (Print and Sign)